

Guía de Cumplimiento del RGPD para Empresas Digitales

Autor: Despacho de Abogados DigitaLex – Especialistas en Derecho Digital

Principios Fundamentales del RGPD

El Reglamento General de Protección de Datos (RGPD), en vigor desde el 25 de mayo de 2018, establece el marco normativo europeo para el tratamiento de datos personales. Sus principios fundamentales —licitud, lealtad y transparencia; limitación de la finalidad; minimización de datos; exactitud; limitación del plazo de conservación; integridad y confidencialidad; y responsabilidad proactiva— constituyen el eje vertebrador sobre el que deben articularse todas las actividades de tratamiento de datos de cualquier organización que opere en el mercado europeo.

La extraterritorialidad del Reglamento es una de sus características más novedosas: cualquier empresa que trate datos de ciudadanos europeos, independientemente de donde esté establecida, queda sujeta a sus disposiciones.

Bases de Legitimación

Para que un tratamiento de datos sea lícito, debe fundamentarse en al menos una de las seis bases legales que el artículo 6 del RGPD establece exhaustivamente: consentimiento del interesado, ejecución de un contrato, cumplimiento de una obligación legal, protección de intereses vitales, misión de interés público o ejercicio de poderes públicos, e interés legítimo del responsable o de un tercero.

La elección incorrecta de la base de legitimación es uno de los errores más frecuentes en la práctica empresarial y constituye una infracción grave que puede ser sancionada con multas de hasta 20 millones de euros o el 4% del volumen de negocio anual global, el importe que sea mayor.

Medidas Técnicas y Organizativas

El RGPD exige la implementación de medidas técnicas y organizativas apropiadas para garantizar un nivel de seguridad adecuado al riesgo. Entre las medidas técnicas más relevantes se encuentran el cifrado de datos en reposo y en tránsito, la seudonimización cuando sea posible, los sistemas de autenticación robusta, los registros de acceso y actividad, y los procedimientos de copia de seguridad verificados.

El Delegado de Protección de Datos (DPD), cuya designación es obligatoria para determinadas categorías de responsables y encargados del tratamiento, actúa como figura de enlace con la autoridad de control y garante interno del cumplimiento normativo.